

Bug Report

Redmineflux DevOps Plugin — Foundation & Infrastructure Suite

Plugin: redmineflux_devops v0.1.0

Redmine Version: 6.0.9

Test Environment: Local Docker + Forge

Test Date: 2026-05-23

Test Suite: tc-01-foundation-infrastructure

Re-verification Date: 2026-05-23

Tested By: Claude (AI QA)

Report Date: 2026-05-23

1
CRITICAL

7
HIGH

3
MEDIUM

2
LOW

13
TOTAL

Executive Summary

Suite 01 (Foundation & Infrastructure) executed 40 test cases covering webhook receiver, connection manager, REST API, activity stream, notification preferences, plugin settings, project navigation, audit log, and access control. 13 defects were filed. All 13 were re-verified on Local Docker on 2026-05-23. 11 confirmed on local; BUG-RDV-008 (Critical IDOR) and BUG-RDV-009 (DORA 404) do not reproduce on local and are classified as Forge-specific pending further investigation.

Risk Area	Rating	Bugs
Security / Authorization	Critical	BUG-RDV-008 (IDOR*), BUG-RDV-011 (wrong permission on webhook log)
Webhook Processing	High	BUG-RDV-002 (no size limit), BUG-RDV-007 (background job fails — commits not stored)
REST API Coverage	High	BUG-RDV-013 (5/10 endpoints 406), BUG-RDV-009 (DORA 404*), BUG-RDV-012 (limit param ignored)
Provider Support	High	BUG-RDV-003 (SonarQube token missing), BUG-RDV-004 (FOSSA missing from form)
Activity Stream	High	BUG-RDV-010 (ActivityProvider not registered)
HTTP Semantics	Low	BUG-RDV-001 (401 vs 403), BUG-RDV-005 (400 vs 404)
Permissions Documentation	Medium	BUG-RDV-006 (3 undocumented permissions)

* Forge-only — does not reproduce on Local Docker.

Test Execution Summary

Result	Count	%
PASS	26	65%
FAIL	10	25%
SKIP	1	2.5%
BLOCKED	3	7.5%
Total	40	100%

BUG-RDV-008 REST API returns DevOps data from all projects regardless of membership (IDOR)

CRITICAL

TC: TC-RDV-022 | **Environment:** Forge only* | **Date:** 2026-05-22 | **Role:** Developer

STEPS TO REPRODUCE

- Obtain API key for a user with membership in only one project.
- Send `GET /devops/builds.json?project_id=<other-project>` with that key.
- Repeat for commits, deployments.

EXPECTED

HTTP 403 Forbidden for all requests to projects the user is not a member of.

ACTUAL

HTTP 200 with full DevOps data (builds, commits) returned from projects the user has no membership in. Classic IDOR / broken access control.

Re-verification 2026-05-23 (Local): **FORGE ONLY** — HTTP 403 returned correctly on local for non-member users. Bug does not reproduce on Local Docker. Forge-specific; re-verify on Forge.

BUG-RDV-002 Webhook endpoint accepts payloads over 2 MB — no size limit enforced

HIGH

TC: TC-RDV-003 | **Environment:** Forge + Local | **Date:** 2026-05-22 | **Role:** System (webhook)

STEPS TO REPRODUCE

- Construct a valid GitHub push payload padded to >2 MB with valid HMAC-SHA256 signature.
- POST to `/devops/webhook/github/phoenix-platform`.

EXPECTED

HTTP 413 Request Entity Too Large for payloads exceeding 2 MB.

ACTUAL

HTTP 202 Accepted. 3 MB payload processed without any size check. DoS risk via memory exhaustion.

Re-verification 2026-05-23 (Local): **CONFIRMED** — 3 MB payload accepted with HTTP 202.

BUG-RDV-003**SonarQube webhook token not configurable via Admin plugin settings UI****HIGH****TC:** TC-RDV-006 | **Environment:** Forge + Local | **Date:** 2026-05-22 | **Role:** Admin**STEPS TO REPRODUCE**

- Navigate to Administration > Plugins > Redmineflux DevOps > Configure .
- Observe available webhook token fields.

EXPECTED

A SonarQube webhook token field alongside Jenkins and Monitoring token fields.

ACTUAL

Only Jenkins and Monitoring token fields present. SonarQube token field absent. Controller reads `sonarqube_webhook_token` setting key, but it is never rendered in the form — all SonarQube webhooks return 401.

Re-verification 2026-05-23 (Local): **CONFIRMED** — Settings page shows Jenkins + Monitoring tokens only. SonarQube field absent.

BUG-RDV-004**FOSSA provider cannot be added as repository connection — missing from Add Repository form****HIGH****TC:** TC-RDV-006 | **Environment:** Forge + Local | **Date:** 2026-05-22 | **Role:** Admin**STEPS TO REPRODUCE**

- Navigate to Project Settings > DevOps > Repositories > Add Repository.
- Open the Provider dropdown and observe the options.

EXPECTED

FOSSA present in Provider dropdown (listed as supported provider in spec).

ACTUAL

Provider dropdown shows: Github, Gitlab, Bitbucket only. FOSSA absent despite being in `SUPPORTED_PROVIDERS` . FOSSA webhooks always return 401 because no connection record can be created.

Re-verification 2026-05-23 (Local): **CONFIRMED** — Provider dropdown: Github, Gitlab, Bitbucket only. No FOSSA option.

BUG-RDV-007

Webhook background job fails with ActiveRecord::RecordInvalid after returning 202

HIGH

TC: TC-RDV-015 | Environment: Forge + Local | Date: 2026-05-22 | Role: System (webhook)

STEPS TO REPRODUCE

- Send valid GitHub push webhook to `/devops/webhook/github/phoenix-platform` with minimal payload (no `repository.html_url` field).
- Observe HTTP response, then check webhook event log for `error_message`.

EXPECTED

HTTP 202 returned; background job completes; commit records persisted in DB.

ACTUAL

HTTP 202 returned (correct), but background job fails: `ActiveRecord::RecordInvalid: Validation failed: Repo url cannot be blank`. Commit records not persisted. Root cause: background job requires `repository.html_url` in the push payload.

Re-verification 2026-05-23 (Local): **CONFIRMED** — Error confirmed in docker logs for event ID 135. Root cause identified: missing `repository.html_url` triggers `RecordInvalid`.

BUG-RDV-009 DORA metrics REST endpoint returns 404 — route not implemented

HIGH

TC: TC-RDV-023 | Environment: Forge only* | Date: 2026-05-22 | Role: Admin

STEPS TO REPRODUCE

- Send `GET /projects/:id/devops_metrics.json` with valid API key on Forge.

EXPECTED

HTTP 200 with DORA metric data (deployment frequency, lead time, MTTR, change failure rate).

ACTUAL

HTTP 404 Not Found on Forge. Route not registered in the plugin's routing table on the Forge deployment.

Re-verification 2026-05-23 (Local): **FORGE ONLY** — HTTP 200 with DORA data returned correctly on local. Route exists in local build. Forge-specific deployment issue.

BUG-RDV-010 DevOps activity events do not appear in Redmine activity stream — ActivityProvider not registered

HIGH

TC: TC-RDV-024, TC-RDV-026 | Environment: Forge + Local | Date: 2026-05-22 | Role: Admin, Developer

STEPS TO REPRODUCE

- Navigate to `/projects/phoenix-platform/activity`.
- Inspect the filter checkboxes in the sidebar.

EXPECTED

DevOps filter categories (Commits, Builds, Deployments) present in the activity sidebar.

ACTUAL

Only 8 standard Redmine filters visible. No DevOps category for any user role including Admin. Plugin does not register a Redmine `ActivityProvider`.

Re-verification 2026-05-23 (Local): **CONFIRMED** — Sidebar filters: Issues, Changesets, News, Documents, Files, Wiki edits, Messages, Spent time. No DevOps category.

BUG-RDV-011

Webhook event log accessible to users with only view_devops — manage_devops_settings not enforced

HIGH

TC: TC-RDV-040 | Environment: Forge + Local | Date: 2026-05-22 | Role: Developer (view_devops only)

STEPS TO REPRODUCE

- Log in as a user with Developer role (has view_devops , does NOT have manage_devops_settings).
- Navigate to /projects/phoenix-platform/devops_webhooks .

EXPECTED

HTTP 403. Webhook event log requires manage_devops_settings permission.

ACTUAL

HTTP 200. Full webhook event log with provider, event type, payload metadata displayed to Developer role users.

Re-verification 2026-05-23 (Local): CONFIRMED — dev_user (Developer role) sees full webhook event log at HTTP 200.

BUG-RDV-013

Five of ten documented REST API endpoints return HTTP 406 — JSON format not supported

HIGH

TC: TC-RDV-023 | Environment: Local | Date: 2026-05-23 | Role: Admin

AFFECTED ENDPOINTS

- GET /projects/:id/devops_environments.json → 406
- GET /projects/:id/devops_incidents.json → 406
- GET /projects/:id/devops_vulnerabilities.json → 406
- GET /projects/:id/devops_releases.json → 406
- GET /projects/:id/devops_alerts.json → 406

EXPECTED / ACTUAL

Expected: HTTP 200 with JSON body for all 10 documented endpoints. Actual: 5 of 10 return HTTP 406 — these controllers do not register a JSON responder, only HTML format is supported.

Re-verification 2026-05-23 (Local): CONFIRMED — All 5 endpoints return 406.

BUG-RDV-006

Three undocumented DevOps permissions present in Roles administration panel

MEDIUM

TC: TC-RDV-007 | Environment: Forge + Local | Date: 2026-05-22 | Role: Admin

EXPECTED

7 DevOps permissions matching requirements.md: view_devops, manage_devops_settings, trigger_builds, approve_deployments, manage_releases, manage_incidents, view_security_scans.

ACTUAL

10 permissions listed. Three extras without specification: **Trigger deployments**, **Approve releases**, **Override security gate**. No documentation, permission guards, or test coverage for these.**Re-verification 2026-05-23 (Local):** CONFIRMED — Roles edit page lists all 10 permissions including the 3 undocumented ones.

BUG-RDV-012

Commits REST API ignores the limit parameter — all records returned on page 1

MEDIUM

TC: TC-RDV-021 | Environment: Local | Date: 2026-05-23 | Role: Admin

EXPECTED

GET /projects/:id/devops_commits.json?limit=5&page=1 returns exactly 5 records. Response includes total_count .

ACTUAL

All 26 records returned on page 1 regardless of limit value. The page /offset parameter is respected but limit is ignored. No total_count field in response.

Re-verification 2026-05-23 (Local): CONFIRMED — limit=3 returns all 26 records.

BUG-RDV-001

Webhook signature rejection returns 401 instead of 403

LOW

TC: TC-RDV-002 | Environment: Forge + Local | Date: 2026-05-22 | Role: System (webhook)

EXPECTED / ACTUAL

Expected: HTTP 403 for invalid HMAC-SHA256 signature. Actual: HTTP 401. Request correctly rejected — only the status code is semantically incorrect per RFC (401 = unauthenticated, 403 = policy refusal).

Re-verification 2026-05-23 (Local): CONFIRMED — HTTP 401 returned for invalid signature.

BUG-RDV-005

Webhook endpoint returns HTTP 400 instead of HTTP 404 for unknown provider

LOW

TC: TC-RDV-004 | Environment: Forge + Local | Date: 2026-05-22 | Role: System (webhook)

EXPECTED / ACTUAL

Expected: HTTP 404 for unrecognized provider name. Actual: HTTP 400 {"error": "Unsupported provider"} . 400 implies malformed request; 404 is semantically correct for a non-existent resource.

Re-verification 2026-05-23 (Local): CONFIRMED — HTTP 400 returned for POST /devops/webhook/unknown_provider/... .

* Forge-only bugs (BUG-RDV-008, BUG-RDV-009) confirmed on Forge 2026-05-22; do not reproduce on Local Docker as of 2026-05-23 re-verification. All 13 bugs remain open pending Forge re-verification.
Generated: 2026-05-23 | Redmineflux DevOps v0.1.0 | Redmine 6.0.9 | Tested by: Claude (AI QA) for Zehntech